



PHP

Sesje i system logowania

Autor: Małgorzata Tokarek



Część 1

Autor: Małgorzata Tokarek

session_start()

W protokole HTTP nagłówki muszą być wysłane przed treścią (body) strony (HTML, tekst, obrazki itp.), zatem `session_start()` powinno być pierwszą linijką w każdym pliku PHP, w którym korzysta się ze zmiennych sesyjnych, czyli zarówno w *index.php* jak i na podstronach.

```
1  <?php
2  session_start();
3  ?>
```

Bezpieczeństwo

Mechanizm sesji jest jednym z elementów dbania o bezpieczeństwo użytkowników w Internecie.



Jak zabezpiecza się hasło w drodze do serwera?

Do serwera wędruje zwykły tekst, kluczową rolę odgrywa protokół HTTPS (szyfrowanie TLS/SSL):

- Zanim jakiegokolwiek dane opuszczą przeglądarkę, całe połączenie (w tym treść formularza POST) zostaje zaszyfrowane kluczem sesyjnym.
- Dostawca Internetu, administrator sieci Wi-Fi czy haker podsłuchujący ruch widzą jedynie nieczytelny strumień bajtów.
- Dane zostają odszyfrowane dopiero wewnątrz pamięci RAM serwera docelowego, gdzie natychmiast trafiają do funkcji haszującej.

Hashowanie hasła

- Stosowany przede wszystkim ze względu na bezpieczeństwo. W bazie danych przechowywany jest jedynie wygenerowany hash. Utrudnia to cyberprzestępcom dostęp do haseł użytkowników, nawet jeśli uda im się włamać do systemu.
- Drugim ważnym czynnikiem jest kwestia ochrony prywatności. Wtedy nawet administratorzy serwisu nie mają dostępu do haseł użytkowników w postaci jawnej.
- W zadaniach szkolnych w bazie przechowujemy jednak zwykłe hasło, a nie hash hasło.

\$_SESSION

`$_SESSION` w PHP to superglobalna tablica asocjacyjna służąca do przechowywania danych użytkownika na serwerze pomiędzy różnymi stronami i żadaniami HTTP w trakcie trwania jednej sesji.

Obsługa jak każdej innej tablicy asocjacyjnej:

Dodanie	Usuwanie
<pre data-bbox="230 1034 981 1281">// Ustawienie statusu zalogowania \$_SESSION['zalogowany'] = true; // Dodanie nazwy użytkownika \$_SESSION['username'] = 'JanKowalski';</pre>	<pre data-bbox="1352 1066 1765 1249">// 1 - wersja \$_SESSION = []; // 2 - wersja \$_SESSION = array() ;</pre>

Ustawianie \$_SESSION

Po zalogowaniu się przez użytkownika (wysłaniu odpowiedniego formularza) ustawia się zmienne sesyjne.

Zanim jednak to nastąpi, należy sprawdzić w bazie danych czy mamy użytkownika o podanym loginie i haśle.

W tym celu należy

1. Sprawdzić czy wypełniono formularz logowania i jeśli tak to dalej:
2. Odczytać wartości z formularza
3. Wysłać odpowiednie zapytanie weryfikacyjne do bazy danych (bez hashowania)

Ustawianie \$_SESSION – krok 1

W tym celu należy:

1. Sprawdzić czy wypełniono formularz logowania i jeśli tak to dalej:
2. Odczytać wartości z formularza
3. Wysłać odpowiednie zapytanie weryfikacyjne do bazy danych (bez hashowania)

```
if ($_SERVER['REQUEST_METHOD']=="POST" &&  
    !empty($_POST['login']) && !empty($_POST['haslo'])) {
```

Ustawianie \$_SESSION – krok 2

W tym celu należy:

1. Sprawdzić czy wypełniono formularz logowania i jeśli tak to dalej:
2. Odczytać wartości z formularza
3. Wysłać odpowiednie zapytanie weryfikacyjne do bazy danych (bez hashowania)

```
$login = $_POST['login'];  
$haslo = $_POST['haslo'];
```

Ustawianie \$_SESSION – krok 3

W tym celu należy:

1. Sprawdzić czy wypełniono formularz logowania i jeśli tak to dalej:
2. Odczytać wartości z formularza
3. Wysłać odpowiednie zapytanie weryfikacyjne do bazy danych (bez hashowania)

```
if ($idPolaczenia){  
    $sql = <<<Zapytanie  
        SELECT id FROM logowanie WHERE login="$login" AND haslo="$haslo";  
        Zapytanie;  
    $wynikZapytania = mysqli_query($idPolaczenia,$sql);  
}
```

Autor: Małgorzata Tokarek

Ustawianie \$_SESSION – kolejne kroki



Ustawianie \$_SESSION

```
$wynikZapytania = mysqli_query($idPolaczenia,$sql);  
if ($wierszZapytania = mysqli_fetch_row($wynikZapytania)){  
    $_SESSION['id']          = $wierszZapytania[0];  
    $_SESSION['login']       = $login;  
    $_SESSION['zalogowany'] = true;  
}  
else {  
    echo "błąd";  
}
```

Testowanie poprawności logowania

Potrzebny jest formularz do logowania oraz przycisk „Zaloguj”

```
29 <!DOCTYPE html>
30 <html lang="en">
31 <head>
32     <meta charset="UTF-8">
33     <meta name="viewport" content="width=device-width, initial-scale=1.0">
34     <title>Document</title>
35 </head>
36 <body>
37     <form action="" method="post">
38         <label for="login">Login</label>
39         <input type="text" name="login" id="login">
40         <label for="haslo"></label>
41         <input type="password" name="haslo" id="haslo">
42         <input type="submit" value="Zaloguj">
43     </form>
44 </body>
45 </html>
```

Autor: Małgorzata Tokarek

Testowanie poprawności logowania

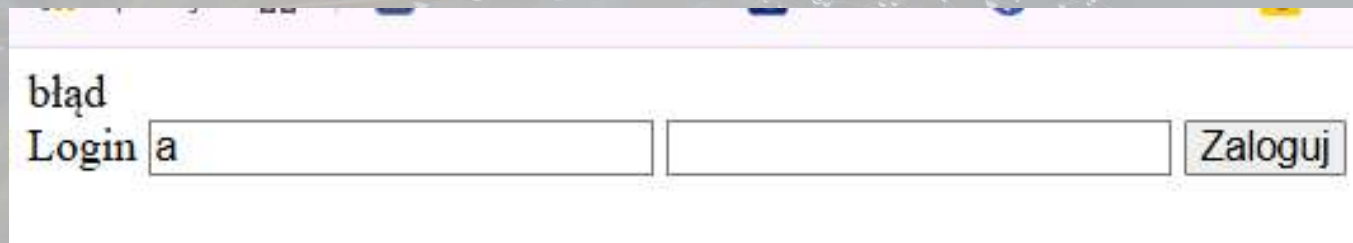
Na potrzeby testowania poprawności logowania dopiszemy linijkę 21, która po pomyślnych testach zostanie usunięta:

```
19     $_SESSION[ 'login' ] = $login;  
20     $_SESSION[ 'zalogowany' ] = true;  
21     echo "Zalogowano $login";  
22 }  
23 else {  
24     echo "błąd";  
25 }
```

Testowanie poprawności logowania

Do testowania należy sprawdzić wcześniej dane do logowania z tabeli

logowanie bazy skorex



A screenshot of a web application's login interface. At the top, a pink header bar contains the text "błąd" (error). Below this, the label "Login" is positioned to the left of two adjacent text input fields. The first input field contains the letter "a". To the right of the second input field is a button labeled "Zaloguj" (Log in).

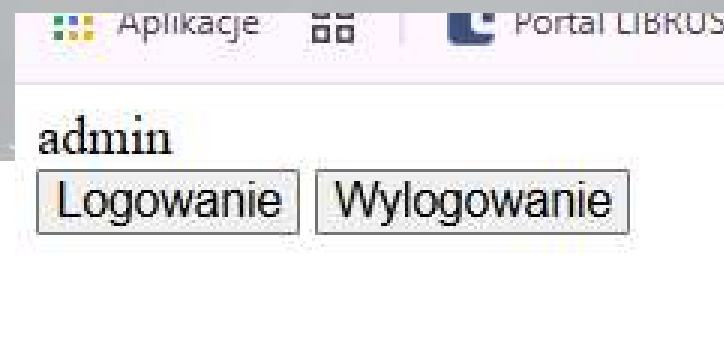


A screenshot of the same web application's login interface. The pink header bar now displays "Zalogowano admin" (Admin logged in). The "Login" label is to the left of two empty text input fields. The "Zaloguj" button remains to the right of the second input field.

Logowanie i wylogowanie - przyciski

Na potrzeby testowania przed przyciskami wyświetlony zostanie komunikat, kto jest zalogowany:

```
<body>
  <?php
    if (isset($_SESSION['login']))
      echo $_SESSION['login'];
    else
      echo "Gość";
  ?>
  <form action="" method="get">
    <input type="submit" value="Logowanie" name="logowanie">
    <input type="submit" value="Wylogowanie" name="wylogowanie">
  </form>
```



Autor: Małgorzata Tokarek

Logowanie

Formularz logowania dostępny tylko po wciśnięciu przycisku *Logowanie*, czyli wysłaniu (get) żądania na serwer. W tym celu

1. Sprawdzane zostaje otrzymanie żądania
2. Dotychczasowy formularz zostanie heredoc'sem

Logowanie –krok 2

W tym celu:

1. Sprawdzane zostaje otrzymanie żądania
2. Dotychczasowy formularz zostanie heredoc'sem

```
if ($_SERVER['REQUEST_METHOD']=='GET' AND isset($_GET['logowanie'])){  
    echo <<<Formularz ...  
}
```

Logowanie –krok 2

W tym celu:

1. Sprawdzane zostaje otrzymanie żądania
2. Dotychczasowy formularz zostanie heredoc'sem

```
echo <<<Formularz
    <form action="" method="post">
        <label for="login">Login</label>
        <input type="text" name="login" id="login">
        <label for="haslo"></label>
        <input type="password" name="haslo" id="haslo">
        <input type="submit" value="Zaloguj">
    </form>
Formularz;
```

Autor: Małgorzata Tokarek

Logowanie całość

Początkowy skrypt obsługujący formularz zostaje bez zmian. Obecna całość dotyczy tylko obsługi przycisków (menu):

```
if ($_SERVER['REQUEST_METHOD']=='GET' AND isset($_GET['logowanie'])){  
    echo <<<Formularz  
        <form action="" method="post">  
            <label for="login">Login</label>  
            <input type="text" name="login" id="login">  
            <label for="haslo"></label>  
            <input type="password" name="haslo" id="haslo">  
            <input type="submit" value="Zaloguj">  
        </form>  
    Formularz;  
}
```

Autor: Małgorzata Tokarek

LogOut – niezbędne czynności (1)

Aby zapewnić pełne i natychmiastowe wylogowanie zaleca się użycie dwóch instrukcji

- ***\$_SESSION = array();*** natychmiast usuwa wszystkie zmienne sesyjne z pamięci RAM bieżącego skryptu.
- ***session_destroy();*** usuwa rzeczywisty plik lub rekord danych sesji przechowywany na serwerze;

LogOut – niezbędne czynności (2)

Dla właściwego efektu można/zaleca się wykonanie jeszcze dwóch instrukcji

- ***header('Location:index.php');*** Wysyła do przeglądarki polecenie, aby natychmiast przeszła pod wskazany adres, tu index.php.
- ***exit;*** Natychmiast zatrzymuje kod, kończy wykonywanie skryptu, aby upewnić się, że żadne inne linijki kodu nie zostaną wykonane po przekierowaniu. Gwarantuje bezpieczeństwo i poprawność, bo nagłówek Location musi być wysłany i przetworzony od razu.

Wylogowanie

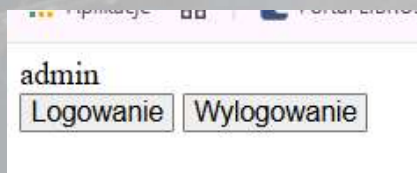
Wylogowanie nastąpi po wciśnięciu przycisku *Wylogowanie*, czyli wysłaniu (get) żądania na serwer. W tym celu

- Sprawdzane zostaje otrzymanie żądania
- Wykonanie 4 instrukcji z dwóch poprzednich slajdów.

Wylogowanie

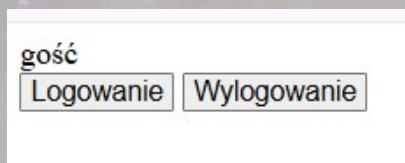
```
if ($_SERVER['REQUEST_METHOD']=='GET' AND isset($_SESSION['zalogowany']))  
&& isset($_GET['wylogowanie']))){  
    $_SESSION = array();  
    session_destroy();  
    header('location:index.php');  
    exit;  
}
```

Aktualne działanie strony



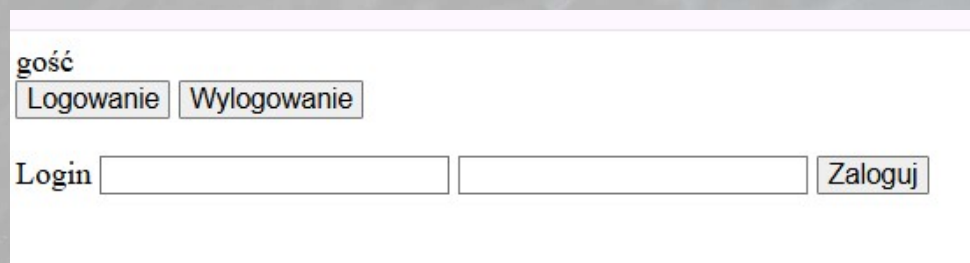
admin

Logowanie Wylogowanie



gość

Logowanie Wylogowanie



gość

Logowanie Wylogowanie

Login Zaloguj

Autor: Małgorzata Tokarek

Zadanie

Wykonaj aplikację webową zawierającą system logowania i mechanizm sesji dla zalogowanych.

Po napisaniu i przetestowaniu skryptów opracuj resztę zawartości (HTML) i wyglądu (CSS) według własnego pomysłu. Używaj znaczników semantycznych, a wszystkie style zdefiniuj w pliku styleIndex.css

Dołącz favicon do swojej aplikacji!!!